

Management review report

This document contains the report on the management review of the Information Security Management System (ISMS) of [ORGANISATION] which was held at [DATE].

This report was created by:

Attendees

1. (CEO)
2. (CTO)
3. (CISO)

Agenda

1. Status of actions from previous review.
2. Changes in internal and external issues (see Ch 4.1 of the ISO standard) that are important to the ISMS
3. Changes in the needs/expectations of interested parties (see Ch 4.2 of the ISO standard) that are relevant for the ISMS.
4. Feedback on performance, based on:
 - Nonconformities (from the external audit, internal audits or other checks)
 - Monitoring and measuring results
 - Audit results
 - Information security objectives
5. Feedback from interested parties
6. Risk assessment and treatment results
7. Opportunities for continuous improvement
8. Formal assessment of the ISMS

Input and outcomes of this meeting

In this meeting for every point on the agenda the CISO has to present the content. We recommend to prepare by placing the substance of the relevant registers here. For example all internal/ external issues, all KPI's and objectives including the most recent scores, highest risks or risk action plans.

In this meeting the management should ask questions and make decisions, e.g. to take action. For example, extra checks, accepting the risks or not accepting the risks. Every meeting there should be 3-5 concrete actions and the management should formally approve the ISMS.

Agenda item	Input-things to discuss which have been written down before the meeting.	Outcomes- Outcomes and actions noted during the meeting
Status of actions from previous review	The actions from the last management review were: 1. ...	
Changes in internal and external topics that are important to the ISMS	[summary or link to overview of internal/external subjects. If necessary a short summary of the changes that have been made.]	Are these up-to-date? What are new subjects?
Changes in the needs/expectations	[summary or link to overview stakeholders. If necessary a	

of stake holders that are relevant for the ISMS.	short summary of new stakeholders, for example by ways of new legislation or new countries we provide services in.]	
Feedback on performance, based on: Nonconformities (from the external audit, internal audits or other checks)	[overview of nonconformities from last audit and their respective corrective action plans. These are typically from previous internal audit]	Has the right action been taken/ planned?
Feedback on performance, based on: Monitoring and measuring results	[present the KPI dashboard, look at a minimum of 2 measurements to see if a trend is emerging]	Are the measurements adequate? Has the right action been taken? Are the correct KPI's listed?
Feedback on performance, based on: audit results	[summary of observations/ opportunities for improvement stemming from the most recent external and internal audits.]	Has the right action been taken/ planned?
Feedback on performance, based on: Evaluation of information security objectives	[summary of the objectives and their current status: is the organization on track to complete its objectives?]	Is the organization on track? Has the right action been taken? Are there new objectives?
Feedback from stakeholders (stakeholder analysis)	[Thinks about the stakeholders with whom there is most contact with]	Are there questions, demands or suggestions from the stakeholders regarding information security?
Risk assessment and treatment results	[[summary of the risk assessment and treatment results including its current status]	When was the last update? Have the corrective action plans been completed?
Opportunities for continual improvement		Have there been suggestions from staff? Are these implemented? Does management have suggestions for improvement?

Formal Decisions in the management review

Management is satisfied with the status of the ISMS. The ISMS is suitable, adequate and effective for our organization and is effectively maintained.

(Optional) Other decisions taken in this meeting are:

...

Summary of the actions resulting from the management review: